

【제 목】 : 개인정보보호 상시모니터링시스템 운영에 관한 사항(개선)

【내 용】

- 우리 원은 국민건강보험법에서 정한 업무를 수행하는 과정에서 전 국민의 진료내역 등 민감정보를 다량 보유하게 됨에 따라 개인정보처리시스템의 안전성 확보 조치 기준을 준수할 의무가 있다.
- 「개인정보 보호법」 제29조 및 행정안전부고시 「개인정보의 안전성 확보조치 기준」 제8조에 따르면 개인정보 침해 등을 예방하기 위해 내부 관리계획 수립, 접속기록 보관 등 안전성 확보에 필요한 기술적·관리적·물리적 조치를 취하도록 되어 있으며, 개인정보처리자는 개인정보의 오·남용 등에 대응하기 위해 개인정보를 다운로드한 것이 발견되었을 경우 내부관리 계획으로 정하는 바에 따라 그 사유를 반드시 확인토록 되어 있다.

☞ 참고자료: 【개인정보 보호법】

제29조(안전조치의무) 개인정보처리자는 개인정보가 분실·도난·유출·위조·변조 또는 훼손되지 아니하도록 내부 관리계획 수립, 접속기록 보관 등 대통령령으로 정하는 바에 따라 안전성 확보에 필요한 기술적·관리적 및 물리적 조치를 하여야 한다.

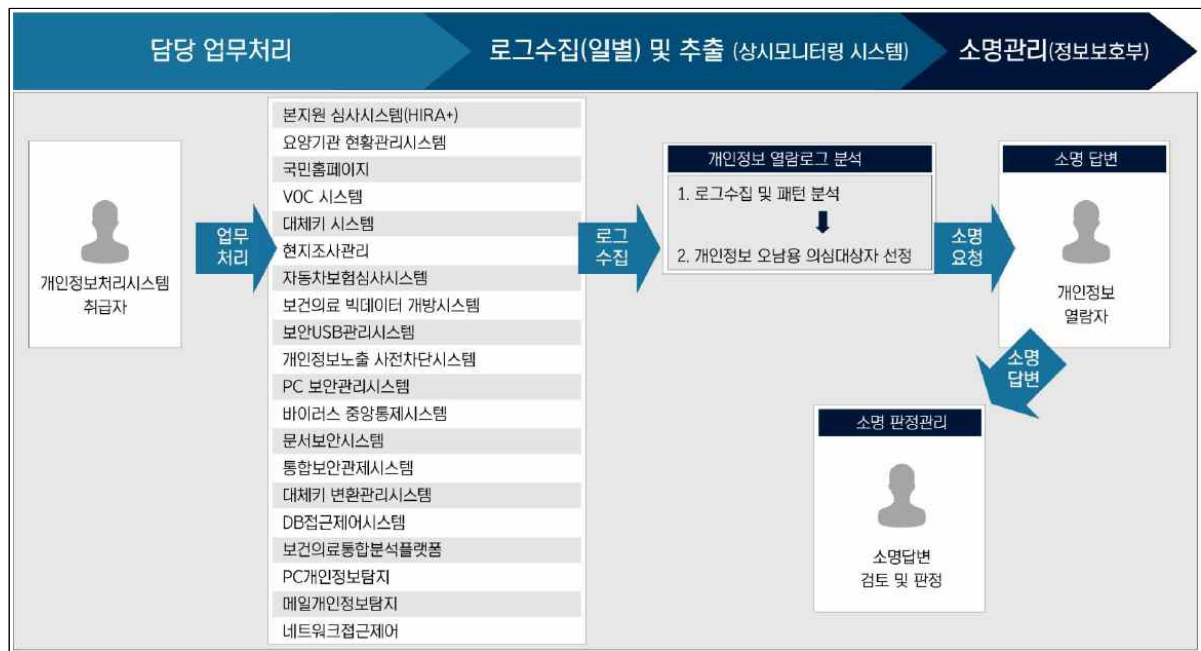
☞ 참고자료: 【개인정보의 안전성 확보조치 기준】 (행정안전부고시 제 2019-47호)

제8조(접속기록의 보관 및 점검) ① 개인정보처리자는 개인정보취급자가 개인정보처리시스템에 접속한 기록을 1년 이상 보관·관리하여야 한다. (생략)

② 개인정보처리자는 개인정보의 오·남용, 분실·도난·유출·위조·변조 또는 훼손 등에 대응하기 위하여 개인정보처리시스템의 접속기록 등을 월 1회 이상 점검하여야 한다. 특히 개인정보를 다운로드한 것이 발견되었을 경우에는 내부관리 계획으로 정하는 바에 따라 그 사유를 반드시 확인하여야 한다. (생략)

- 이와 관련하여, ICT전략실에서는 개인정보의 안전성 확보를 위한 ‘개인정보보호 상시모니터링시스템’을 운영하고 있으며,
  - 심사시스템, 보건의료 빅데이터 개방시스템 등 우리 원 업무시스템에서 처리한 로그를 수집·분석하여, 개인정보 오남용 의심 업무 처리자(소명대상자)에게 소명 후 그 결과를 검토·판정하는 업무를 수행하고 있다.

☞ 참고자료: 【개인정보 상시모니터링 업무 흐름】



- 개인정보보호 상시모니터링시스템은 개인정보의 불법유출, 오남용 및 침해로 인한 피해를 예방하기 위해 상시 운영해야하며 의심사례가 발생할 경우 적시에 검토 및 판정할 수 있어야 한다.
- 이에 감사대상기간 동안 개인정보보호 상시모니터링시스템을 점검한 결과, 【표】 ‘개인정보보호 상시모니터링시스템 처리 현황’ 에서와 같이 소명요청부터 소명판정까지 걸린 기간은,
  - 총 458건 중 10일 이내 처리 349건(전체의 76.2%), 10일 초과 처리 84건(전체의 18.3%)이었으며, 이 중 30일 초과 10건, 250일 초과 1건, 미처리 25건을 확인하였는바,
  - 소명대상자가 소명한 기간과 소명 후 검토·판정까지 걸린 기간을 확인할 수 없었으며, 소명 및 검토·판정까지의 기간이 정해져있지 않아 일부의 경우 처리가 지연되는 등의 사실을 확인하였다.
  - 따라서, 우리 원의 개인정보처리시스템 안전성 확보 등을 규정한 「개인정보 내부관리지침」에 개인정보보호 상시모니터링시스템의 소명기간, 검토·판정기간 등을 명시하여 운영할 필요가 있다.

**【표】 개인정보보호 상시모니터링시스템 처리 현황**

| 전체             | 처리일별 현황(2018.06.01.~2021.06.07.) |               |               |              |              |
|----------------|----------------------------------|---------------|---------------|--------------|--------------|
|                | 0~10일 이하                         | 11~20일 이하     | 21~30일 이하     | 31~60일 이하    | 61일 이상       |
| 458건<br>(100%) | 371건<br>(81.0%)                  | 44건<br>(9.6%) | 31건<br>(6.8%) | 9건<br>(1.9%) | 3건<br>(0.7%) |

**【조치할 사항】**

- 기획상임이사는 「개인정보 내부관리지침」에 개인정보보호 상시모니터링시스템의 업무처리 기준을 명시하는 등 개인정보보호 상시모니터링 업무를 강화하기 위한 방안을 마련하시기 바랍니다. (개선)